

AAA Digital Platform — Platform Administration Guide

Version 1.0 · 26 July 2026 · Confidential — Ambitious about Autism

Who can administer the platform, what each kind of administrator controls, and where the boundary between the charity and an external organisation sits. Read this before granting anyone an administrative account.

This document is regenerated from markdown via `npm run handover:build` — see `docs/handover/README.md` for the build process.

Companion documents. This guide covers the *administration model* — the shape of authority on the platform. For step-by-step screen instructions see the **Admin Guide** (`AAA_Admin_Guide.pdf`), which contains the full Charity Admin and Org Admin walkthroughs.

1. The Short Answer

Administration is **two-tier**. The charity does not administer everything, and external organisations are not passive tenants.

- **Ambitious about Autism** controls the *content* and *who gets it* — training programmes, the document library, surveys, platform-wide job openings, cohorts, AI behaviour and the creation of organisations themselves.
- **Each external organisation** — a school, college, academy, university or employer — administers *its own people and its own day-to-day running*: users, workshops, its own job openings, announcements, reports, SSO and meeting credentials.

The dividing line is deliberate and worth stating plainly:

An organisation can add as many users as it likes, but it cannot grant itself training the charity has not assigned. It distributes what it has been given; it does not extend it.

2. The Four Roles

The platform has exactly four roles. Three of them administer something.

Role (in the database)	Shown in the UI as	Scope of authority	Lands on
<code>SUPER_ADMIN</code>	Charity Admin	The whole platform. Every permission, implicitly.	<code>/super-admin</code>
<code>CHARITY_EMPLOYEE</code>	Charity Employee	Charity-level, but only the areas ticked on their account.	<code>/super-admin</code>
<code>ORG_ADMIN</code>	Org Admin	One organisation (plus its child organisations, if it is a parent).	<code>/admin</code>
<code>LEARNER</code>	Learner	Their own training. No administrative access.	<code>/dashboard</code>

There is **no** role for students, careers officers, caregivers or interns any more. Those ten legacy roles collapsed into the single `LEARNER` role in July 2026. What a learner sees is decided by their organisation's assigned training programmes, not by their job title.

Internal versus external is a property of the organisation, not the person. The charity has its own organisation record (organisation type `CHARITY`), and charity staff are ordinary members of it. A charity employee taking a course is a `LEARNER` in the charity's own organisation; a charity employee administering the platform holds `CHARITY_EMPLOYEE` or `SUPER_ADMIN`.

3. Charity-Level Administration

Charity administrators work under `/super-admin`. Anyone whose role is not `SUPER_ADMIN` or `CHARITY_EMPLOYEE` is redirected away from every page in that area before it renders.

3.1 The main navigation

Item	Path	Who sees it
Overview	<code>/super-admin</code>	All charity-level users
Feedback	<code>/super-admin/feedback</code>	Charity Admin only

Organisations	/super-admin/organisations	Needs <i>Manage Organisations</i>
Products	/super-admin/products	All charity-level users (contents are individually gated)
Reports	/super-admin/reports	Needs <i>View Reports</i>
Subscribers	/super-admin/subscribers	Charity Admin only
Users	/super-admin/users	Charity Admin only
Settings	/super-admin/settings	Charity Admin only

3.2 The Products hub

Everything the charity publishes to the platform lives behind **Products**. Each tile is gated independently, so a charity employee sees only the tiles their permissions unlock.

Tile	Path	Permission required
AI Prompts	/super-admin/ai-prompts	Manage AI Prompts
Announcements	/super-admin/announcements	Manage Announcements
Brand Assets	/super-admin/brand-assets	Manage Library
Catalogue — Education	/courses?audience=education	None (public page)
Catalogue — Employer	/courses?audience=employer	None (public page)
Cohorts	/super-admin/cohorts	Manage Cohorts
Document Library	/super-admin/library	Manage Library
Home Page	/super-admin/home	Charity Admin only
Job Openings	/super-admin/jobs	Manage Job Openings
Surveys	/super-admin/surveys	Manage Surveys
Training Content	/super-admin/training	Manage Training
Workshops	/super-admin/sessions	Manage Workshops

3.3 Platform settings

Setting	Path	What it controls
---------	------	------------------

Appearance	<code>/super-admin/settings/appearance</code>	Colour theme applied across the platform
Meeting Configuration	<code>/super-admin/settings/meetings</code>	Charity-level Zoom / Teams API credentials
SSO Configuration	<code>/super-admin/settings/sso</code>	Charity SAML SSO, and the Google / Microsoft sign-in toggles
Integrations	<code>/super-admin/settings/integrations</code>	API keys for Power BI, Dynamics 365 and Power Automate
Eventbrite	<code>/super-admin/settings/eventbrite</code>	Eventbrite private token and attendee email-match policy

3.4 Charity-only powers

These have no organisation-level equivalent. An org admin cannot do any of them, by any route:

- **Create organisations.** A school cannot provision another school.
- **Assign training programmes.** This is the control that decides what an organisation's learners can access.
- **Author training content** — programmes, modules, lessons, quizzes, SCORM imports.
- **Publish platform-wide job openings, surveys, cohorts and announcements.**
- **Configure AI prompts and models.**
- **Issue integration API keys.**
- **Enable Google and Microsoft sign-in** for the whole platform.
- **Edit home pages** — including an individual organisation's own home page (see §11).
- **Deactivate an organisation**, which immediately blocks every one of its users at sign-in.

4. Delegated Charity Access — Charity Employees

`CHARITY_EMPLOYEE` exists so charity staff can be given some platform-wide authority without handing over all of it. Each account carries a list of permissions; the navigation and the Products hub filter themselves to match, and every API route re-checks the permission server-side.

There are **ten** permissions:

Permission	Label in the UI	Unlocks
------------	-----------------	---------

<code>manage_organisations</code>	Manage Organisations	Provision and edit organisations; cohorts
<code>manage_cohorts</code>	Manage Cohorts	Cohort membership management
<code>manage_training</code>	Manage Training	Programmes, modules, lessons, quizzes, SCORM
<code>manage_surveys</code>	Manage Surveys	Create, publish and analyse surveys
<code>manage_announcements</code>	Manage Announcements	Platform-wide and org-scoped announcements
<code>view_reports</code>	View Reports	Cross-organisation reporting and exports
<code>manage_sessions</code>	Manage Workshops	Charity-level virtual classroom sessions
<code>manage_library</code>	Manage Library	Document collections, uploads and brand assets
<code>manage_ai_prompts</code>	Manage AI Prompts	The AI prompt registry and model selection
<code>manage_jobs</code>	Manage Job Openings	Charity-tier job openings

A **Charity Admin** holds all ten implicitly — the check short-circuits on the role, so nothing needs to be ticked.

Five surfaces are **never** available to a charity employee, whatever their permissions: Feedback, Subscribers, platform-wide Users, Home Page editing, and **Settings**. These are Charity Admin only by design, because they touch billing, personal data across every organisation, platform-wide identity configuration, or the account model itself.

The Settings link is visible in the sidebar to charity employees but the page itself turns them away, as does every settings API behind it. Treat the whole of Settings — appearance, meeting credentials, SSO, integrations and Eventbrite — as Charity Admin territory.

Granting permissions. Permissions are set per user under **Users** (`/super-admin/users`), which is Charity Admin only. A charity employee therefore cannot widen their own access or anyone else's.

5. Organisation-Level Administration

An **ORG_ADMIN** works under `/admin`. Everything they see is automatically scoped to their own organisation — the scoping is applied server-side from their session, not from anything the browser sends, so it cannot be widened by editing a request.

Surface	Path	What it does
Users	<code>/admin</code>	Create, edit, deactivate the organisation's own users
Announcements	<code>/admin/announcements</code>	Notices shown to this organisation only
Billing	<code>/admin/billing</code>	Subscription and invoices
Catalogue	<code>/courses</code>	The public course catalogue (opens in a new tab)
Document Library	<code>/admin/library</code>	Collections the charity has targeted at this organisation
Enterprise SSO	<code>/admin/settings/sso</code>	The organisation's own SAML configuration
Job Openings	<code>/admin/jobs</code>	The organisation's own vacancies (see §10)
Home	<code>/home</code>	The home page their members see (view only)
Meeting Settings	<code>/admin/settings/meetings</code>	The organisation's own Zoom / Teams credentials
Reports	<code>/admin/reports</code>	Training completion for their own people
Workshops	<code>/admin/sessions</code>	Schedule and run virtual classroom sessions
Schools	<code>/admin/schools</code>	Child organisations — parent organisations only (see §6)
Settings	<code>/admin/settings</code>	Appearance preferences

What an org admin cannot do

- Reach any `/super-admin` page — the middleware redirects them to `/admin`.
- See or affect another organisation's users, reports or job openings.
- Create or edit training content, or assign a programme to themselves.
- Edit their own organisation's home page.
- **Create another Org Admin.** New users must have a role that appears in the organisation's `allowedRoles` list, and provisioning sets that list to `LEARNER` only. If a second administrator is genuinely needed, the charity widens the list — it is not self-service.

6. Parent Organisations and Child Schools

An organisation can be marked as a **parent**. A multi-academy trust, a college group or an employer with several sites is the usual case.

- A **Schools** item appears in the parent's navigation at `/admin/schools`.
- The parent admin creates and manages child organisations and their users from there.
- Child organisations with **inherit settings** enabled take their parent's training programmes and permitted roles automatically.
- A parent's job openings are visible to the learners of its child organisations as well as its own.
- The admin APIs accept an organisation parameter for drill-down, and every one of them verifies the parent actually owns that child before answering.

The hierarchy is **one level deep**. A child organisation cannot itself have children.

7. What Decides What a Learner Sees

This is the single most important thing to understand about the platform's access model, and it is where most questions land.

Access flows from the organisation's **assigned training programmes**, not from the user's role.

1. The charity assigns one or more training programmes to an organisation.
2. Every member of that organisation resolves those programmes at sign-in, and they are carried in the session.
3. The learner's sidebar renders one navigation item per assigned programme.
4. Server-side checks on training content, progress and SCORM assets all re-verify the programme against the session — so a learner cannot reach a programme their organisation has not been given, even with a direct link.

The practical consequence: **to change what an organisation can access, change its programme assignment**. Nothing else — not roles, not permissions, not user counts — has that effect.

8. Provisioning a New School or Company

Provisioning is a single guided flow at `/super-admin/organisations`, available to a Charity Admin or a charity employee with *Manage Organisations*.

Step	What you supply
1 — Organisation	Name, URL slug, and type (School, College, Academy, University or Employer)
2 — Training	The training programmes this organisation's learners will receive
3 — Administrator	Name and email of the person who will run the organisation
4 — Contact details	Optional contact name, phone and postal address

On submit, the platform creates the organisation, its administrator account, and an activation token **together in one transaction** — so a half-provisioned organisation with no way in cannot be left behind. It then emails the administrator an activation link.

What is created	Detail
Organisation	Active, permitted roles set to LEARNER , programmes as chosen
Administrator	Role ORG_ADMIN , no password — they set one via the activation link
Activation link	Valid for 7 days ; nothing is sent in plain text

The email is sent *after* the transaction commits, so a mail failure never rolls back a correctly created organisation. If the email does not arrive, the screen says so — reissue it from the organisation's user list rather than provisioning again.

The charity's own organisation type is **not offered** in this flow. There is exactly one charity organisation, seeded once during setup, and it must not be recreatable.

9. Adding and Managing Users

Route in	Who does it	How it works
Provisioning	Charity	Creates the first Org Admin with an activation link
Org admin invites	Org Admin	Creates a user with a temporary password; the user must change it at first sign-in. A printable card with a QR code can be produced for handing over in person.
SSO-only account	Org Admin	No password at all; the user signs in through the organisation's SAML provider
SAML auto-provisioning	Automatic	If enabled on the organisation's SSO config, an unknown but valid SAML user is created on first sign-in

Self-registration	The user	Registering at <code>/register</code> sends a magic link; the user chooses their own password and is signed straight in. No approval queue.
OAuth sign-up	The user	An unrecognised Google or Microsoft sign-in is routed through a short sign-up step and placed in the Public Toolkit organisation

Deactivate rather than delete. Setting a user inactive blocks them at sign-in immediately while preserving their training history and any reporting that depends on it. Deactivating an *organisation* blocks all of its users the same way.

10. Job Openings — Two Tiers

Ownership of a job opening decides who can see it and who can edit it.

Tier	Owner	Visible to	Managed at
Charity	No owning organisation	Every learner on the platform, optionally narrowed to chosen organisations	<code>/super-admin/jobs</code>
Organisation	One organisation	That organisation's learners, and its child organisations' learners	<code>/admin/jobs</code>

The owning organisation is taken from the administrator's session, never from the submitted form. An org admin therefore cannot publish into another organisation, nor onto the charity tier, and the charity's own listings are not editable from the organisation endpoints.

A job can also be **assigned to an individual learner**, in which case it appears for them even if it was not otherwise aimed at their organisation. Listings close automatically after their closing date.

11. Home Pages

Every signed-in user sees a home page at `/home`. Which one they get is decided by their **organisation**:

- If their organisation has its own home page, they see that.
- Otherwise they see the **platform default**.
- If an organisation's page exists but has been emptied of content, its members fall back to the default rather than landing on a blank page.

Both are edited at `/super-admin/home`, with an organisation picker to switch between the default and any individual organisation's override. Removing an override returns that organisation's

members to the default.

Editing is Charity Admin only. An organisation cannot customise its own home page — it must ask the charity. This is a deliberate choice to keep brand and messaging under central control. If it should change, the underlying data model already supports it; only the permission check would need relaxing.

12. How Access Is Actually Enforced

Every request passes through middleware before any page renders. The checks run in this order, and the first one that matches wins.

Check	Outcome
Not signed in, on a protected path	Redirect to <code>/login</code> , preserving the intended destination
Password change required	Redirect to <code>/change-password</code> ; API calls are refused
MFA verification pending	Redirect to <code>/mfa-verify</code> ; API calls are refused
Administrator without MFA configured	Redirect to <code>/mfa-setup</code> ; API calls are refused
<code>/super-admin/*</code> requested by a non-charity role	Redirect to that role's own home page
<code>/admin/*</code> requested by anyone who is not an Org Admin	Redirect to that role's own home page
An administrator requesting learner-only pages	Redirect home — except that charity-level users may preview training, careers and library pages as a learner sees them
Request for <code>/</code>	Redirect to the role's home page

Middleware is the outer gate, not the only one. Every API route re-checks the session and the relevant permission itself, so blocking a page does not depend on the redirect alone.

13. Security Requirements for Administrator Accounts

Control	Applies to	Detail
---------	------------	--------

Two-factor authentication	Charity Admin, Charity Employee, Org Admin	Mandatory. An administrator without TOTP configured cannot reach any page until they enrol.
Session length	Everyone	8 hours, then re-authentication
Password hashing	Everyone	bcrypt, cost factor 12
Sign-in rate limit	Everyone	10 attempts per 15 minutes
Forced password change	Invited users	Anyone given a temporary password must replace it at first sign-in
Activation and reset tokens	Everyone	Stored hashed, never in plain text. Three lifetimes are in use: organisation-admin activation links 7 days , self-registration welcome links 24 hours , password resets 1 hour

The MFA kill-switch. Setting `DISABLE_MFA=true` skips all enrolment and verification. It exists for recovery situations — for example, an administrator locked out after losing their authenticator. Existing TOTP secrets survive untouched. **It must not be left on in production**, and turning it on should be treated as an incident with a recorded reason and a time by which it will be turned off again.

14. Responsibility Matrix

Task	Charity Admin	Charity Employee	Org Admin
Create an organisation	✓	With <i>Manage Organisations</i>	✗
Assign training programmes	✓	With <i>Manage Organisations</i>	✗
Author training content	✓	With <i>Manage Training</i>	✗
Publish platform-wide jobs	✓	With <i>Manage Job Openings</i>	✗
Publish the organisation's own jobs	✓	With <i>Manage Job Openings</i>	✓ (own organisation)

Create and publish surveys	✓	With <i>Manage Surveys</i>	✗
Manage the document library	✓	With <i>Manage Library</i>	View and edit collection details only
Cross-organisation reports	✓	With <i>View Reports</i>	✗
Own organisation's reports	✓	With <i>View Reports</i>	✓
Schedule workshops	✓	With <i>Manage Workshops</i>	✓ (own organisation)
Add and deactivate users	✓ (anywhere)	✗	✓ (own organisation)
Grant charity permissions	✓	✗	✗
Configure SAML SSO	✓ (charity-level)	✗	✓ (own organisation)
Enable Google / Microsoft sign-in	✓	✗	✗
Configure AI prompts	✓	With <i>Manage AI Prompts</i>	✗
Issue integration API keys	✓	✗	✗
Edit home pages	✓	✗	✗
Deactivate an organisation	✓	With <i>Manage Organisations</i>	✗

15. When an Organisation Must Contact the Charity

An org admin should raise a request with Ambitious about Autism for any of the following. None of them are self-service, and all are quick for the charity to action.

- Access to an additional training programme.
- A second administrator for the organisation.
- A custom home page for the organisation.
- Being set up as a parent organisation, or adding a child organisation to an existing parent.
- Correcting an organisation name, slug or type.
- Reinstating a deactivated organisation.

16. Known Gaps

Recorded here so they are not mistaken for faults during handover.

- **There is no audit log.** The platform does not record an administrator activity trail — who changed what, and when. An *Audit Log* navigation item existed briefly but pointed at a page that was never built, and has been removed rather than left as a dead link. If the charity needs an audit trail for assurance or data-protection purposes, it is a piece of work to specify and build, not a setting to switch on.
- **Home page editing is centralised.** As noted in §11, organisations cannot edit their own home page. This is intentional today; revisit if the charity would rather delegate it.